VULNERABILITY ASSESSMENT REPORT

1. INTRODUCTION

This report presents the findings of a security review conducted on the OWASP Juice Shop website. The goal was to identify common security weaknesses that could put the website and its visitors at risk.

This review was carried out using passive, read-only methods. No hacking, login attempts, or harmful actions were performed.

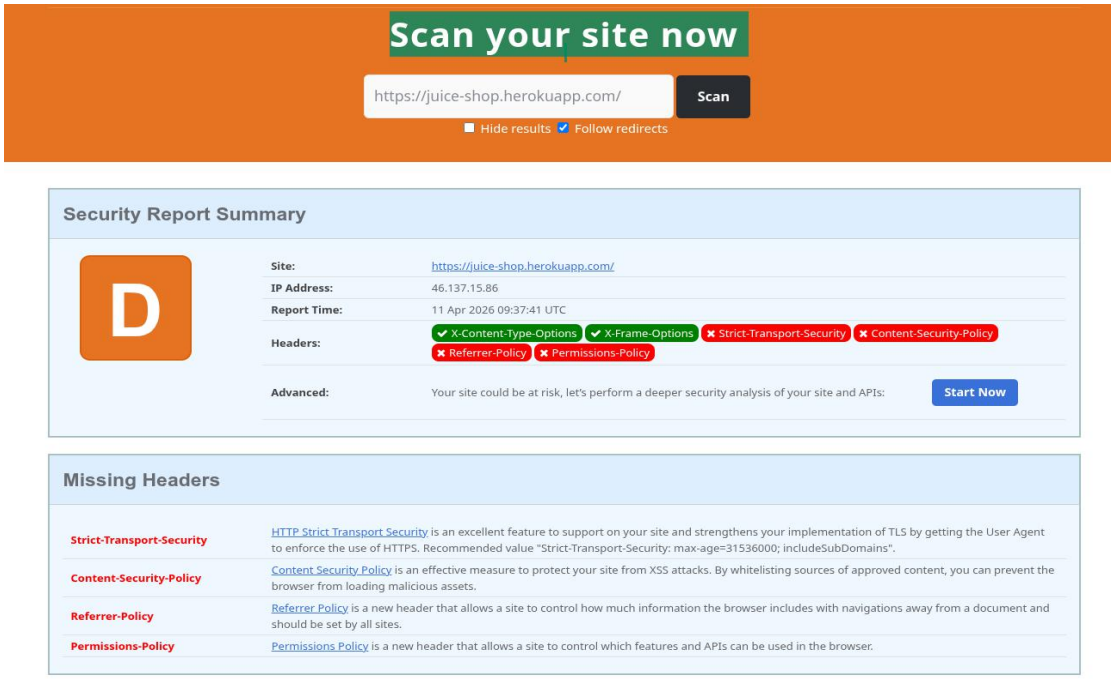
2. ABOUT THE WEBSITE

Detail	Info
Website	juice-shop.herokuapp.com
Hosting	Amazon Web Services (AWS)
Purpose	Public demo web application
Review Type	Passive

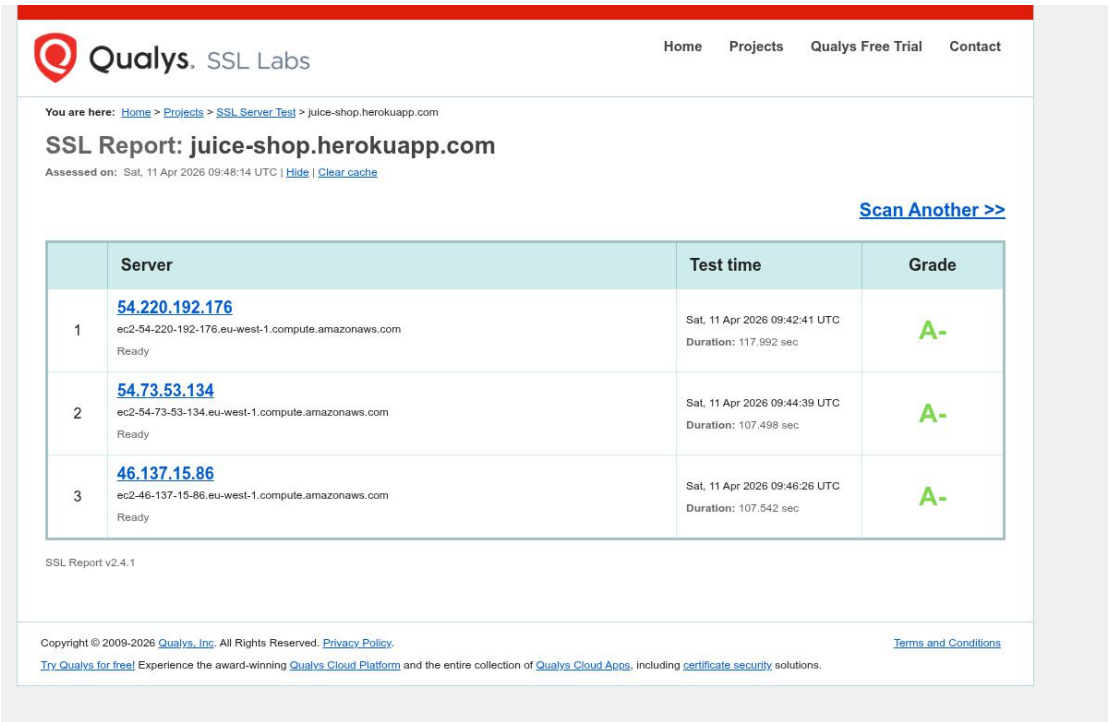
3. OVERALL SECURITY SCORE

Tool Used	Score/Grade
Security Headers	D
SSL Labs	A-
Mozilla Observatory	35/100 (D)

Security Headers Analysis Results



SSL Labs Results



Mozilla Observatory Results

HTTP Observatory Report

Report Feedback

HTTP C

Tests

FAQ

Scan summary: juice-shop.herokuapp.com

D

Score: 35 / 100
Scan Time: 6 hours ago
Tests Passed: 7 / 10

↗ since last scan

Rescan

Scan another website

Scan results

Scoring | CSP analysis | Cookies | Raw server headers | Scan history | Benchmark comparison

Test	Score	Reason	Recommendation
Content Security Policy (CSP)	-25 ✗	Content Security Policy (CSP) header not implemented	Implement one, see MDN's Content Security Policy (CSP) documentation.
Cookies	-	No cookies detected	None
Cross Origin Resource Sharing (CORS)	0 ✓	Public content is visible via cross-origin resource sharing (CORS) `Access-Control-Allow-Origin` header.	None
Redirection	-20 ✗	Does not redirect to an HTTPS site.	Redirect to the same host on HTTPS first, then redirect to the final host on HTTPS.
Referrer Policy	-	`Referrer-Policy` header not implemented.	Set to `strict-origin-when-cross-origin` at a minimum.
Strict Transport Security (HSTS)	-20 ✗	`Strict-Transport-Security` header not implemented.	Add HSTS. Consider rolling out with shorter periods first (as suggested on https://hstspreload.org/).
Subresource Integrity	-	Subresource Integrity (SRI) not implemented, but all scripts are loaded from a similar origin.	Add SRI for bonus points.
X-Content-Type-Options	0 ✓	`X-Content-Type-Options` header set to `nosniff`.	None
X-Frame-Options	0* ✓	`X-Frame-Options` (XFO) header set to `SAMEORIGIN` or `DENY`.	None
Cross Origin Resource Policy	-	Cross Origin Resource Policy (CORP) is not implemented (defaults to `cross-origin`).	None

4. FINDINGS

No	vulnerability	Info	Impact	Risk Level	Solution
01	Missing SecurityTransport Policy	The website does not force visitors to always use a secure connection. An attacker on the same network (like a coffee shop WiFi) could intercept the connection before it becomes secure.	Customer data could be exposed without them knowing.	High	HTTPS-only connections on the server so all visitors are automatically protected.
02	Missing Content Security Policy	he website has no rules about what content is allowed to load on its pages.	Attackers could inject harmful scripts into the website pages that steal user information.	High	Add a content security policy that only allows trusted content to load on the website.
03	No Automatic Redirect to Secure Connection	When someone visits the website without typing "https://", they are not automatically sent to the secure version.	Any customer who visits without the secure link is unprotected.	High	Set up automatic redirection so every visitor always lands on the secure version of the website.
04	Missing Referrer Policy	The website shares too much information when visitors click links to other websites.	Internal page details could be exposed to third party websites	medium	Add a referrer policy to control what information is shared when visitors leave the website.
05	Missing Permissions Policy	The website has not set rules about which device features websites are allowed to access. Without these rules, malicious scripts could potentially access a visitor's camera, microphone or location	Visitor privacy could be compromised without their knowledge.	medium	Add a permissions policy to restrict access to sensitive device features.

06	Missing Cross Origin Resource Policy	The website does not restrict which other websites can load its resources.	Website resources could be misused by unauthorized third parties.	medium	Set a cross origin resource policy to control who can access the website's resources.
07	SSL Certificate Not Fully Optimized	The website has an SSL certificate (which is good) but it scored A- instead of a perfect A.	While connections are encrypted, the overall protection is not at the highest level.	medium	Fixing the missing headers above will automatically improve this score to A.

7. CONCLUSION

The website has a valid SSL certificate which is a good foundation. However several important security settings are missing that leave visitors exposed to unnecessary risks.

The good news is that all findings identified in this report can be fixed without rebuilding the website. These are configuration changes that a developer can implement quickly.

Fixing these issues will significantly improve the website's security score and better protect its visitors.